

RISK TREATMENT PLAN (RTP)

VitalCloud Health
ISO/IEC 27001:2022 / HIPAA Compliant

Document Title	Risk Treatment Plan (RTP)
Document Number	VC-RTP-001
Version	1.0
Classification	Internal — Confidential
Author	GRC Consulting Team / ISMS Manager
Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Issue Date	May 19, 2026
Next Review Date	May 19, 2027
Distribution List	ISMS Steering Committee, CISO, HIPAA Officers, IT Security, Risk Committee, Department Heads

1. Introduction

This Risk Treatment Plan (RTP) documents the selected treatment options, control implementations, responsibilities, deadlines, and residual risks for all identified risks in VitalCloud Health's Information Security Management System (ISMS). It is a mandatory document under ISO/IEC 27001:2022 Clause 6.1.3 and supports HIPAA Security Rule risk management requirements.

Purpose: To systematically address identified information security risks through appropriate treatment options, ensuring that residual risks are within VitalCloud Health's risk appetite and aligned with business objectives, patient safety, and regulatory compliance.

Scope: This plan covers all 20 risks identified in the Risk Assessment Report (VC-RAR-001), spanning telehealth platforms, IoT medical devices, Legacy Care Clinics, cloud infrastructure, third-party relationships, and personnel risks.

Risk Appetite Statement: VitalCloud Health has a LOW risk appetite for risks affecting PHI confidentiality, patient safety, and telemedicine service availability. MEDIUM risk appetite is acceptable for operational efficiency risks. HIGH risk appetite is NOT acceptable for any HIPAA-regulated activity.

2. Risk Treatment Methodology

Risk treatment follows ISO 27001:2022 Clause 6.1.3 and NIST SP 800-30 Rev. 1 guidance. Four treatment options are considered:

Risk Mitigation: Apply controls from ISO 27001:2022 Annex A, HIPAA Security Rule safeguards, and industry best practices to reduce likelihood and/or impact. This is the PRIMARY treatment option for VitalCloud Health.

Risk Transfer: Transfer risk to third parties through cyber insurance, Business Associate Agreements (BAAs), and contractual liability clauses. Used for vendor-related risks.

Risk Avoidance: Discontinue the activity or process that creates the risk. Used when risk exceeds appetite and mitigation is not feasible.

Risk Acceptance: Knowingly accept residual risk when it is within risk appetite and cost of treatment exceeds benefit. Requires formal management approval and documentation.

2.1 Control Selection Criteria

Controls are selected based on the following criteria:

1. Effectiveness: Does the control adequately address the identified risk?
2. Feasibility: Can the control be implemented given technical, financial, and organizational constraints?
3. Cost-Benefit: Does the benefit of risk reduction justify the implementation cost?
4. Regulatory Alignment: Does the control satisfy HIPAA, ISO 27001, or other applicable requirements?
5. Synergy: Does the control address multiple risks simultaneously?
6. Operational Impact: Can the control be implemented without disrupting patient care or telemedicine services?

2.2 Residual Risk Assessment

After control implementation, residual risk is re-assessed using the same 5×5 matrix (Likelihood × Impact). Residual risk must meet the following acceptance criteria:

- Extreme risks (17-25): Must be reduced to Medium (5-9) or lower
- Very High risks (13-16): Must be reduced to Medium (5-9) or lower
- High risks (10-12): Must be reduced to Low (3-4) or lower
- Medium risks (5-9): Acceptable if within risk appetite and monitored
- Low/Very Low risks (1-4): Acceptable with routine monitoring

Any residual risk that does NOT meet these criteria requires additional treatment or formal risk acceptance with executive approval.

3. Risk Treatment Register

The following table details the treatment plan for each identified risk, including selected controls, owners, deadlines, and expected residual risk post-treatment.

Risk ID	Risk Description	Treatment Option	Selected Controls	Control Owner	Deadline	Residual Risk	Status
R001	Unauthorized PHI access via weak access controls on EHR and legacy systems	Mitigation	A.5.15 (Access Control), A.5.16 (Identity Mgmt), A.5.17 (Authentication), A.8.2 (Privileged Access), A.8.5 (Secure Auth), A.8.12 (DLP)	CISO / IT Security Officer	Sep 2026	Medium (6)	Planned
R002	Man-in-the-middle attack on telemedicine video streams via outdated TLS	Mitigation	A.8.24 (Cryptography), A.8.20 (Network Security), A.8.21 (Secure Network Services), A.5.14 (Info Transfer)	IT Security Officer / DevOps Lead	Aug 2026	Medium (6)	Planned
R003	IoT device compromise via unencrypted data and weak authentication	Mitigation	A.8.1 (Endpoint Devices), A.8.20 (Network Security), A.8.24 (Cryptography), A.5.21 (ICT Supply Chain), A.8.9 (Config Mgmt)	IoT Security Engineer / CISO	Oct 2026	Medium (6)	Planned
R004	Unauthorized physical access to paper PHI records at Legacy Care Clinics	Mitigation	A.7.1 (Physical Perimeters), A.7.2 (Physical Entry), A.7.3 (Secure Areas), A.7.4 (Physical Monitoring), A.6.3 (Awareness Training)	Clinic Operations / HIPAA Privacy Officer	Mar 2027	Medium (6)	Planned
R005	Ransomware attack on unencrypted legacy clinic on-site servers	Mitigation	A.8.7 (Malware Protection), A.8.8 (Vulnerability Mgmt), A.8.9 (Config Mgmt), A.8.13 (Info Backup), A.8.20 (Network Security), A.8.22 (Network Segregation)	CIO / IT Director	Feb 2027	Low (4)	Planned
R006	Unauthorized patient portal access via compromised	Mitigation	A.5.15 (Access Control), A.5.17 (Authentication Info), A.8.5	Mobile App Dev Lead / IT Security	Sep 2026	Medium (6)	Planned

	credentials without MFA		(Secure Auth), A.8.1 (Endpoint Devices), A.8.24 (Cryptography)				
R007	Data exfiltration from legacy imaging equipment with outdated OS and no encryption	Mitigation	A.8.8 (Vulnerability Mgmt), A.8.9 (Config Mgmt), A.8.24 (Cryptography), A.5.9 (Asset Inventory), A.5.10 (Acceptable Use)	Biomedical Engineering / IT Security	Dec 2026	Low (4)	Planned
R008	Encryption key compromise or loss leading to unrecoverable PHI	Mitigation	A.5.29 (Cryptographic Solutions), A.8.24 (Use of Cryptography), A.8.2 (Privileged Access), A.8.15 (Logging)	Cryptography Engineer / CISO	Aug 2026	Low (3)	Planned
R009	Insider threat from independent practitioners with excessive privileges and no background checks	Mitigation	A.5.15 (Access Control), A.5.18 (Access Rights), A.6.1 (Screening), A.6.2 (Terms of Employment), A.6.6 (NDAs), A.7.9 (Assets Off-Premises)	HR / HIPAA Privacy Officer	Sep 2026	Medium (6)	Planned
R010	Privileged insider abuse by system administrators viewing any patient record	Mitigation	A.8.2 (Privileged Access), A.8.3 (Info Access Restriction), A.8.15 (Logging), A.8.16 (Monitoring), A.5.3 (Segregation of Duties)	CISO / IT Security Officer	Oct 2026	Medium (6)	Planned
R011	Accidental PHI disclosure by untrained legacy clinic staff via social engineering	Mitigation	A.6.3 (Awareness Training), A.6.4 (Disciplinary Process), A.5.10 (Acceptable Use), A.8.12 (DLP), A.5.14 (Info Transfer)	HR / Training Coordinator	Aug 2026	Low (4)	Planned
R012	API abuse and data scraping on telemedicine platform due to weak authentication	Mitigation	A.8.20 (Network Security), A.8.21 (Secure Network Services), A.8.26 (App Security Requirements), A.8.28 (Secure	API Dev Lead / IT Security	Oct 2026	Low (4)	Planned

			Coding), A.5.15 (Access Control)				
R013	Cloud misconfiguration exposing EHR database to public access	Mitigation	A.5.23 (Cloud Services), A.8.9 (Config Mgmt), A.8.20 (Network Security), A.8.22 (Network Segregation), A.8.16 (Monitoring)	Cloud Security Engineer / CISO	Sep 2026	Medium (6)	Planned
R014	SQL Injection / XSS attack on patient portal leading to PHI exposure	Mitigation	A.8.25 (Secure SDLC), A.8.26 (App Security), A.8.28 (Secure Coding), A.8.29 (Security Testing), A.8.20 (Network Security)	DevSecOps Lead / CISO	Oct 2026	Low (4)	Planned
R015	Extended telemedicine service outage during disaster with no DR plan	Mitigation	A.5.24 (BC Planning), A.5.25 (ICT Readiness), A.5.26 (Availability Requirements), A.5.27 (Redundancy), A.8.14 (Redundancy)	BC Manager / IT Director	Dec 2026	Low (4)	Planned
R016	Vendor data breach by third-party cloud provider affecting VitalCloud PHI	Transfer	A.5.19 (Supplier Relationships), A.5.20 (Supplier Agreements), A.5.21 (ICT Supply Chain), A.5.22 (Supplier Monitoring), Cyber Insurance	CISO / Legal / Procurement	Aug 2026	Medium (6)	Planned
R017	Intellectual property theft of proprietary telehealth algorithms by employee	Mitigation	A.8.4 (Source Code Access), A.5.32 (IP Rights), A.5.10 (Acceptable Use), A.8.15 (Logging), A.8.12 (DLP)	CISO / Legal / Dev Lead	Nov 2026	Low (3)	Planned
R018	Failure to securely delete patient data upon Right to be Forgotten request	Mitigation	A.8.10 (Info Deletion), A.8.11 (Data Masking), A.5.33 (Records Protection), A.5.34 (Privacy of PII)	Data Protection Officer / CISO	Oct 2026	Low (3)	Planned
R019	PHI sent via unencrypted email by staff using personal	Mitigation	A.8.12 (DLP), A.8.24 (Cryptography), A.5.14 (Info	IT Security / Email Admin	Aug 2026	Low (4)	Planned

	accounts		Transfer), A.5.10 (Acceptable Use), A.6.3 (Awareness Training)				
R02 0	Theft of equipment containing PHI from HQ or clinic locations	Mitigation	A.7.1 (Physical Perimeters), A.7.2 (Physical Entry), A.7.4 (Physical Monitoring), A.7.8 (Equipment Siting), A.7.14 (Secure Disposal)	Facilities / Security Manager	Dec 2026	Low (3)	Planned

4. Control Implementation Details

This section provides detailed implementation guidance for the primary controls selected across all risks. Each control includes implementation steps, dependencies, validation criteria, and resource requirements.

A.5.15 — Access Control

Implementation Steps:

1. Deploy Role-Based Access Control (RBAC) across all systems containing PHI
2. Define roles: Patient, Practitioner, Nurse, Admin, System Admin, Auditor
3. Map each role to minimum necessary permissions (least privilege)
4. Implement quarterly access reviews with automated reminders
5. Deploy emergency access procedures for critical care situations

Dependencies: Identity Management System (A.5.16), Authentication (A.5.17)

Validation: Access review completion rate $\geq 95\%$, unauthorized access attempts detected within 30 min

Resources: \$40,000 | 2 FTEs | 3 months

A.5.17 — Authentication Information

Implementation Steps:

1. Enforce Multi-Factor Authentication (MFA) on ALL systems with PHI access
2. Implement strong password policy: min 12 chars, complexity, 90-day rotation
3. Deploy Single Sign-On (SSO) with MFA for telemedicine portal
4. Implement certificate-based authentication for IoT devices
5. Deploy password manager for privileged accounts

Dependencies: Identity Provider (Azure AD / Okta), Mobile Device Management

Validation: MFA enrollment 100%, password policy compliance $\geq 98\%$, brute force attempts blocked

Resources: \$60,000 | 1 FTE | 2 months

A.8.24 — Use of Cryptography

Implementation Steps:

1. Encrypt all PHI at rest using AES-256 (databases, file systems, backups)
2. Enforce TLS 1.3 for all data in transit (web, APIs, email)
3. Implement end-to-end encryption (E2EE) for telemedicine video streams (WebRTC + DTLS-SRTP)
4. Deploy Hardware Security Module (HSM) or Cloud KMS for key management
5. Encrypt IoT device data transmission (AES-128 minimum)

Dependencies: Cloud provider encryption services, certificate infrastructure

Validation: Encryption coverage 100%, vulnerability scan confirms no cleartext PHI

Resources: \$80,000 | 1 FTE | 2 months

A.8.7 — Protection Against Malware

Implementation Steps:

1. Deploy Endpoint Detection and Response (EDR) on all endpoints and servers
2. Implement anti-malware with real-time scanning and automatic updates
3. Deploy email gateway with anti-phishing, sandboxing, and attachment scanning
4. Implement application whitelisting on critical systems (EHR, telemedicine)
5. Conduct quarterly malware simulation tests

Dependencies: EDR vendor selection, email gateway deployment

Validation: EDR coverage 100%, malware detection rate $\geq 99\%$, zero successful ransomware

Resources: \$100,000 | 1 FTE | 2 months

A.8.13 — Information Backup

Implementation Steps:

1. Implement daily automated backups of all critical data (EHR, telemedicine, configs)
2. Encrypt backups using AES-256 with separate key management
3. Store backups in geographically separated locations (multi-region cloud)
4. Implement immutable backup storage (WORM) to prevent ransomware deletion
5. Conduct quarterly backup restoration tests with documented results

Dependencies: Cloud storage infrastructure, backup software

Validation: Backup success rate $\geq 99\%$, RTO ≤ 4 hours, RPO ≤ 24 hours

Resources: \$50,000 | 1 FTE | 2 months

A.7.1 — Physical Security Perimeters

Implementation Steps:

1. Install electronic access control at all Legacy Care Clinic locations
2. Deploy CCTV with 90-day retention at all facilities
3. Implement visitor management system with photo ID and escort requirements
4. Secure server rooms and data centers with biometric access
5. Install alarm systems with central monitoring

Dependencies: Physical security vendor, facility modifications

Validation: 100% facility coverage, zero unauthorized physical access incidents

Resources: \$150,000 | 1 FTE | 6 months

A.5.24 — ICT Readiness for Business Continuity

Implementation Steps:

1. Develop comprehensive Business Continuity Plan (BCP) for telemedicine and clinics
2. Deploy redundant infrastructure across multiple availability zones/regions
3. Implement automated failover for EHR and telemedicine platform
4. Install UPS and generators at critical clinic locations
5. Develop manual procedures for clinic operations during system outages
6. Conduct semi-annual disaster recovery drills

Dependencies: Cloud infrastructure, facility upgrades

Validation: Failover test success $\geq 95\%$, telemedicine uptime $\geq 99.9\%$, DR drill completion 100%

Resources: \$200,000 | 2 FTEs | 6 months

A.6.3 — Information Security Awareness, Education and Training

Implementation Steps:

1. Develop HIPAA + security awareness training curriculum (online + in-person)
2. Deploy Learning Management System (LMS) for training tracking
3. Mandate annual training for all staff, contractors, and practitioners
4. Conduct quarterly phishing simulations with metrics tracking
5. Provide role-specific training: developers (secure coding), admins (privileged access), clinical staff (PHI handling)
6. Track completion rates and escalate non-compliance to management

Dependencies: LMS platform, training content development

Validation: Training completion 100%, phishing simulation click rate $< 5\%$, zero repeat violations

Resources: \$30,000 | 1 FTE | 3 months

5. Treatment Schedule & Milestones

The following schedule outlines the phased implementation of risk treatments aligned with the 12-month certification timeline.

Phase	Timeline	Focus Areas	Risks Addressed	Budget	Milestone
Phase 1: Foundation	Q2 2026 (Months 1-3)	Risk assessment validation, policy finalization, access control baseline, encryption deployment, asset inventory completion	R001, R008, R013, R018, R019	\$250,000	All policies approved, MFA baseline deployed, encryption coverage ≥80%
Phase 2: Implementation	Q3 2026 (Months 4-6)	MFA full deployment, SIEM operational, DLP deployment, network segmentation, IoT security, training rollout	R002, R003, R006, R009, R010, R011, R012, R014	\$450,000	MFA 100%, SIEM live, DLP deployed, network segmented, IoT encrypted
Phase 3: Remediation	Q4 2026 (Months 7-9)	Legacy clinic migration, patch management, incident response testing, BAA execution, physical security upgrades	R004, R005, R007, R015, R016, R020	\$600,000	Legacy servers migrated, clinics on cloud EHR, IR plan tested, all BAAs signed
Phase 4: Validation	Q1 2027 (Months 10-12)	Internal audit, external certification audit, HIPAA compliance validation, continuous monitoring, policy refinement	R001-R020 (all residual risk validation)	\$425,000	ISO 27001 certificate, HIPAA attestation, all residual risks acceptable

5.1 Gantt Chart Summary

Key treatment activities timeline:

MONTH 1-2:

- Finalize ISMS documentation and policies
- Deploy MFA on critical systems (EHR, telemedicine portal)

- Begin encryption deployment (AES-256 at rest, TLS 1.3 in transit)
- Complete asset inventory and classification

MONTH 3-4:

- Deploy SIEM and configure alerting rules
- Implement network segmentation (VLANs for IoT, EHR, corporate)
- Launch security awareness and HIPAA training program
- Begin legacy clinic server assessment and migration planning

MONTH 5-6:

- Deploy DLP solution across all channels (email, web, USB)
- Implement IoT device encryption and certificate authentication
- Deploy API gateway with rate limiting and OAuth 2.0
- Complete background checks for all independent practitioners

MONTH 7-8:

- Begin Legacy Care Clinic server migration to cloud EHR
- Deploy EDR across all endpoints and servers
- Install CCTV and access control at all clinic locations
- Conduct first incident response tabletop exercise

MONTH 9-10:

- Complete legacy clinic migration and decommission old servers
- Execute all Business Associate Agreements
- Deploy PAM solution for privileged accounts
- Conduct vulnerability scan and penetration test

MONTH 11-12:

- Conduct internal audit (ISO 27001 + HIPAA)
- Remediate any audit findings
- Engage external certification body for ISO 27001 audit
- Validate all residual risks are within appetite
- Obtain ISO 27001:2022 certificate and HIPAA compliance attestation

6. Residual Risk Summary

After implementation of all treatment controls, the following residual risk profile is projected. All residual risks must be formally accepted by the Risk Committee and documented in the Risk Register.

Risk Level	Pre-Treatment Count	Post-Treatment Count	Reduction	Acceptance Status
Extreme (17-25)	2	0	100%	N/A — All mitigated
Very High (13-16)	6	0	100%	N/A — All mitigated
High (10-12)	6	0	100%	N/A — All mitigated
Medium (5-9)	6	8	N/A	Accepted with monitoring
Low (3-4)	0	8	N/A	Accepted with routine monitoring
Very Low (1-2)	0	4	N/A	Accepted with routine monitoring

6.1 Risk Acceptance Criteria

Residual risks are accepted based on the following criteria:

1. Residual risk score is within VitalCloud Health's risk appetite (Low or Very Low preferred; Medium acceptable with monitoring)
2. Cost of further treatment exceeds the benefit of additional risk reduction (cost-benefit analysis documented)
3. The risk is inherent to the business model and cannot be practically eliminated (e.g., third-party vendor risks)
4. Compensating controls are in place that reduce the practical impact below the theoretical score
5. Management has reviewed and formally approved the residual risk with documented justification

Risk Acceptance Process:

- Residual risk documented in Risk Register with justification
- Risk Committee reviews and votes on acceptance
- CISO and CEO sign formal Risk Acceptance Memo
- Accepted risks reviewed quarterly in management review
- If risk environment changes, accepted risks are re-evaluated immediately

6.2 Ongoing Risk Monitoring

Accepted residual risks are continuously monitored through:

- Quarterly risk register reviews by the Risk Committee
- Monthly KPI dashboards tracking control effectiveness
- Real-time SIEM alerting for indicators of accepted risks materializing
- Annual penetration testing and vulnerability assessments
- Vendor security assessments for transferred risks
- Incident trend analysis to detect emerging patterns

Monitoring Metrics for Accepted Risks:

- R016 (Vendor breach): Quarterly vendor risk scorecards, annual SOC 2 reviews, continuous dark web monitoring
- R017 (IP theft): Monthly DLP alerts, quarterly source code access reviews, annual IP audit
- R018 (Data deletion): Quarterly deletion request fulfillment audits, data mapping accuracy reviews
- R020 (Physical theft): Monthly CCTV review, quarterly asset inventory audits, annual physical security assessment

7. Roles and Responsibilities

Clear accountability ensures timely and effective risk treatment implementation.

Role	Treatment Responsibilities	Decision Authority	Reporting
CEO / Incident Commander	Approve risk appetite, resource allocation, and residual risk acceptance. Champion security culture.	Final authority on all risk treatment decisions, budget approval, and risk acceptance	Board of Directors
CISO	Oversee all risk treatment activities. Ensure alignment with ISO 27001 and HIPAA. Coordinate cross-functional implementation.	Authority on control selection, vendor selection, and security architecture decisions	CEO / Board
ISMS Manager / GRC Manager	Maintain Risk Register and RTP. Track treatment progress. Conduct risk reviews. Report metrics.	Authority on risk assessment methodology, risk scoring, and compliance reporting	CISO
HIPAA Privacy Officer	Ensure all PHI-related treatments comply with HIPAA Privacy Rule. Oversee patient rights and breach workflows.	Authority on PHI handling procedures, patient notification decisions, and privacy controls	CISO / CEO
HIPAA Security Officer	Implement and validate HIPAA technical safeguards. Assess ePHI protection measures. Oversee security training.	Authority on encryption standards, access controls, and security technology decisions	CISO
IT Security Officer	Execute technical control implementation. Manage SIEM, EDR, DLP, and network security tools. Respond to incidents.	Authority on firewall rules, monitoring configurations, and vulnerability remediation prioritization	CISO
IT Director / CIO	Oversee infrastructure changes, cloud migration, legacy system decommissioning, and business continuity planning.	Authority on architecture decisions, vendor selection for infrastructure, and DR planning	CISO / CEO
Department Heads	Ensure departmental compliance with risk treatments. Support staff training and awareness. Report control gaps.	Authority on departmental procedure changes and resource allocation within their domain	CISO / HR
Control Owners	Implement specific controls per RTP. Maintain control documentation. Report control status and effectiveness.	Authority on control implementation methods, scheduling, and validation within their assigned control	ISMS Manager
Risk Committee	Review risk assessments, approve treatment plans, accept residual risks, and	Authority on risk acceptance, treatment prioritization, and risk	CISO / CEO

	monitor risk trends.	appetite adjustments	
--	----------------------	----------------------	--

8. Budget and Resource Allocation

The following budget breakdown supports the 12-month risk treatment implementation plan.

Category	Phase 1 (Q2)	Phase 2 (Q3)	Phase 3 (Q4)	Phase 4 (Q1 2027)
Technology & Tools	\$120,000	\$280,000	\$350,000	\$150,000
Professional Services	\$50,000	\$80,000	\$150,000	\$150,000
Training & Awareness	\$20,000	\$30,000	\$30,000	\$25,000
Infrastructure Upgrades	\$30,000	\$30,000	\$50,000	\$50,000
Legacy Clinic Migration	\$0	\$0	\$200,000	\$0
Physical Security	\$10,000	\$10,000	\$100,000	\$20,000
Cyber Insurance	\$10,000	\$10,000	\$10,000	\$10,000
Contingency (10%)	\$24,000	\$42,000	\$60,000	\$40,000
TOTAL	\$264,000	\$482,000	\$950,000	\$445,000

8.1 Resource Requirements

Human Resources:

- 2 FTE Security Engineers (MFA, SIEM, DLP deployment)
- 1 FTE Cloud Security Engineer (cloud hardening, CSPM)
- 1 FTE IoT Security Engineer (device encryption, firmware management)
- 1 FTE GRC Analyst (risk tracking, compliance reporting, audit preparation)
- 1 FTE Training Coordinator (awareness program, phishing simulations)
- 0.5 FTE Forensics Specialist (on-demand retainer with external vendor)

External Resources:

- External ISO 27001 certification body (Q1 2027)
- HIPAA compliance auditor (Q4 2026)
- Penetration testing firm (quarterly)
- Forensics investigation firm (on-demand retainer)
- Cyber insurance broker and carrier

9. Review and Maintenance

The Risk Treatment Plan is a living document that must be regularly reviewed and updated to remain effective.

9.1 Review Schedule

Review Type	Frequency	Participants	Focus
Monthly Progress Review	Monthly	ISMS Manager + Control Owners	Treatment implementation status, blockers, resource needs
Quarterly Risk Review	Quarterly	Risk Committee + CISO	Residual risk validation, new risks, risk appetite review
Annual Comprehensive Review	Annually	All IRT + Executive Team	Full RTP refresh, control effectiveness, budget reallocation
Post-Incident Review	After each P1/P2 incident	IRT + GRC + HIPAA	Treatment effectiveness, control gaps, lessons learned
Trigger-Based Review	As needed	Relevant stakeholders	Major system changes, acquisitions, regulatory changes, audit findings

9.2 Triggers for Immediate RTP Update

- New risk identified with score $\geq$ Medium (5)
- Existing risk score changes by ≥ 3 points (up or down)
- Control implementation failure or significant delay (>30 days past deadline)
- Major organizational change (acquisition, divestiture, new service line)
- Significant technology change (cloud migration, new EHR system, IoT platform upgrade)
- Regulatory change affecting HIPAA, ISO 27001, or state privacy laws
- Post-incident review identifies control gaps requiring new treatments
- Vendor breach or third-party security incident affecting VitalCloud
- Annual internal or external audit findings requiring treatment changes
- Cyber insurance policy changes affecting risk transfer strategy

9.3 Version Control

All changes to the RTP are tracked through formal version control:

- Version number: Major.Minor (e.g., 1.0, 1.1, 2.0)
- Major version: Significant structural changes, new risk categories, or annual refresh
- Minor version: Individual risk updates, control changes, or deadline adjustments
- Change log maintained with: date, author, change description, approval
- Previous versions archived for 6 years per HIPAA requirements
- All changes approved by ISMS Manager and CISO before publication

10. Document Approval

This Risk Treatment Plan has been reviewed and approved by the following authorized personnel:

Name	Title	Signature	Date
[Name]	Chief Executive Officer (CEO)	_____	_____
[Name]	Chief Information Security Officer (CISO)	_____	_____
[Name]	ISMS Manager / GRC Manager	_____	_____
[Name]	HIPAA Security Officer	_____	_____

This document is the property of VitalCloud Health. Unauthorized disclosure, copying, or distribution is prohibited. All control owners must acknowledge their assigned treatments and report progress monthly. This plan shall be reviewed at least quarterly and updated upon significant changes to the risk landscape.